

Penetration Testing Report

Mediroza General Hospital

Batch: B082 | Week 4

Target: <https://medirozahospital.com>

Engagement Type: Black-box Penetration Test

Duration: 3 Days

Prepared by: Vijay Solanki

Date: September 13, 2026

CONFIDENTIAL — AUTHORISED PERSONNEL ONLY

1. Executive Summary

Networkwalks conducted a 3-day authorised black-box penetration test against the Mediroza General Hospital web infrastructure (<https://medirozahospital.com>) as part of Batch B082, Week 4. The engagement scope covered the patient-facing web application only, with no social engineering or denial-of-service testing permitted.

The assessment identified critical weaknesses in the patient portal's login mechanism, in the encryption applied to confidential patient pathology reports, and in the exposure of an internal database backup file on the web server. Together these findings allowed a tester to gain unauthorised access to confidential patient lab reports, recover their contents by defeating weak passwords, and retrieve highly sensitive internal records covering staff personal data, salaries, and hospital shareholding structure.

Two findings are rated Critical, one High, and one Medium. Immediate remediation is recommended, particularly around input validation on the login endpoint and removal of the publicly accessible backup file.

2. Scope and Methodology

Client	Mediroza General Hospital
Target	https://medirozahospital.com
Engagement Type	Full black-box penetration test
Rules of Engagement	Testing limited to the target domain only. No social engineering. No denial of service. No testing outside agreed scope.
Authorisation	Written authorisation was provided by the client to conduct security testing on their web infrastructure.
Duration	3 days
Tools Used	Kali Linux, Burp Suite, browser developer tools, PDF hash extraction and dictionary-based password cracking tools

3. Findings and Proof of Exploitation

3.1 M1 — SQL Injection Leading to Unauthorised Access (Critical)

Reconnaissance of the Patient Portal login page (medirozahospital.com/patient/login.php) identified that submitted input was passed into a backend SQL query without proper sanitisation. Submitting a crafted value containing a single quote produced a raw MySQL syntax error (`mysqli_query()` warning), confirming the field was directly concatenated into the query and that the application was vulnerable to SQL Injection.

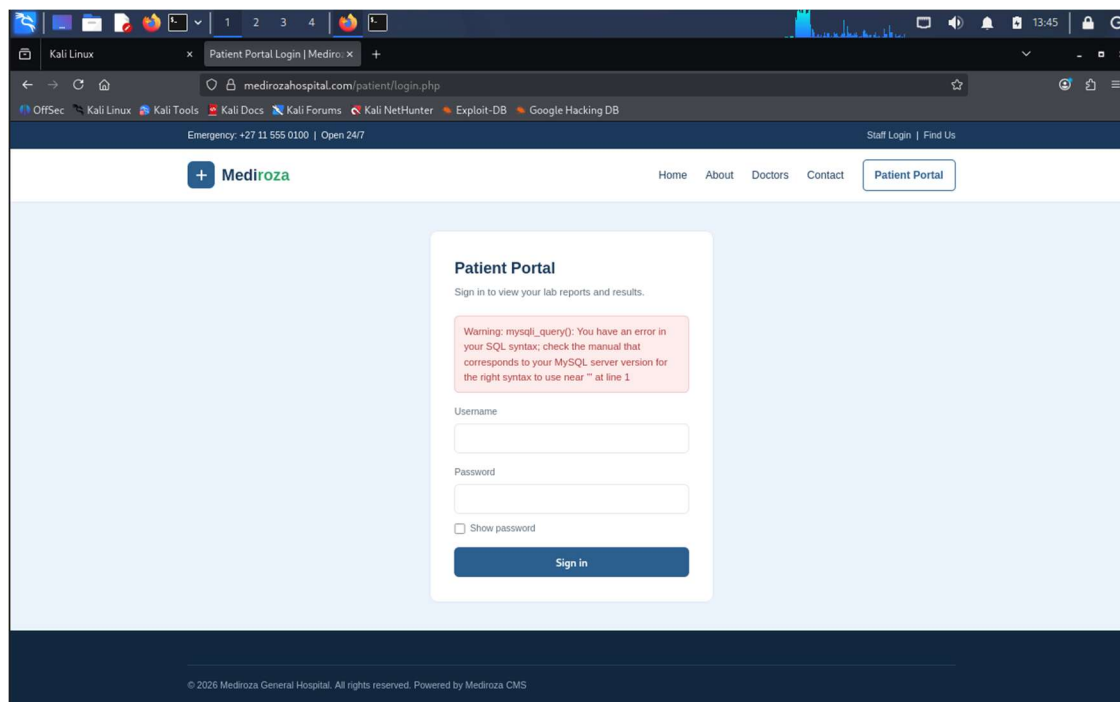


Figure 1. SQL syntax error returned by the Patient Portal login form, confirming unsanitised input reaching the backend query.

The login form's authentication logic was then probed further using Burp Suite to intercept and modify login requests with SQL injection payloads. While early attempts returned "Incorrect password", iterative refinement of the payload against the username and password parameters ultimately bypassed the authentication check, granting unauthorised access to the restricted patient area of the site.

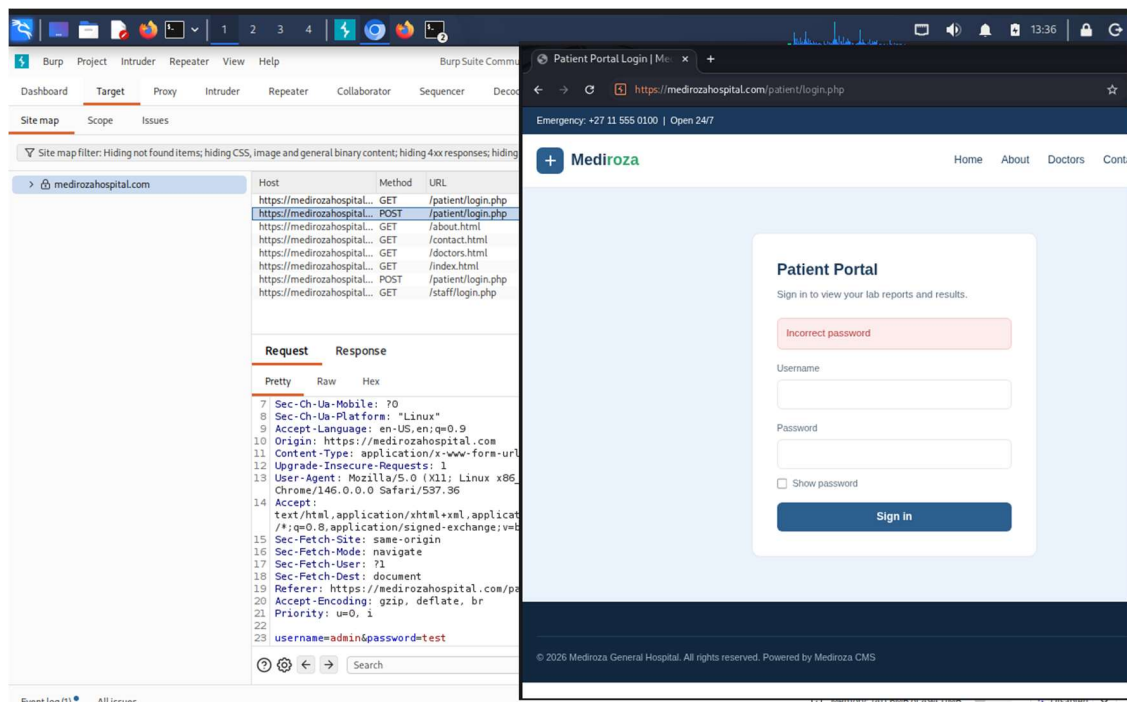


Figure 2. Burp Suite intercepting a login request during SQL injection testing against the authentication mechanism.

Using this access, three confidential patient pathology lab report PDFs were retrieved from the portal, satisfying the Milestone 1 deliverable.

3.2 M2 — Weak Encryption on Retrieved PDF Reports (High)

Each of the three retrieved PDF lab reports was found to be password-protected using standard PDF encryption (PDF R3, 128-bit, MD5 key derivation with RC4). The password hash was extracted from each file and subjected to a dictionary attack, following the same principle used by tools such as John the Ripper.

The first file's password was recovered almost immediately, matching the common weak password "123456" within the first two attempts of a 100-entry wordlist.

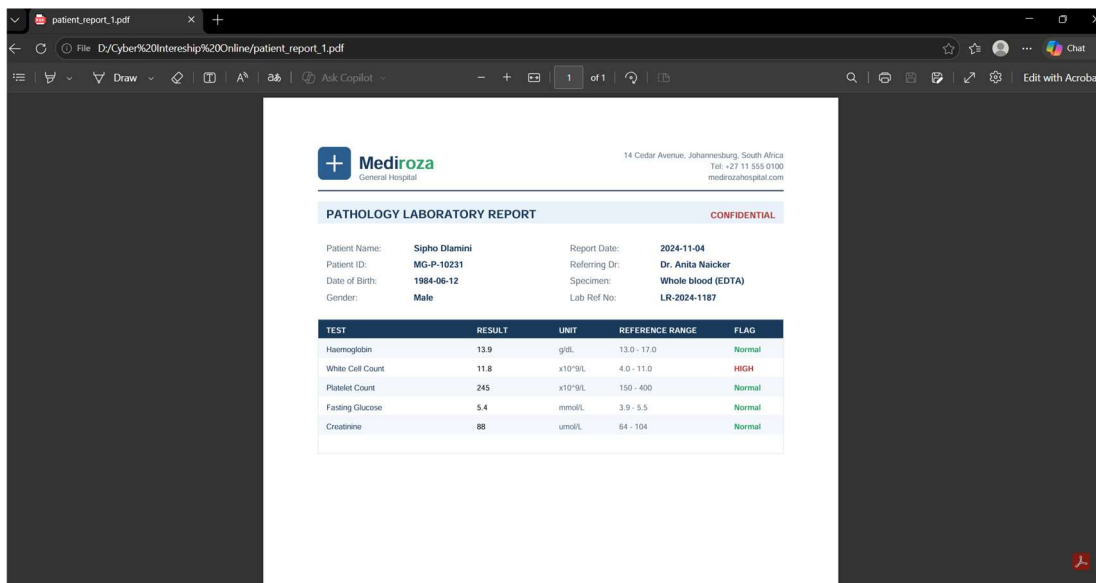


Figure 3. Retrieved and decrypted patient_report_1.pdf — pathology lab report for patient Siphso Dlamini.

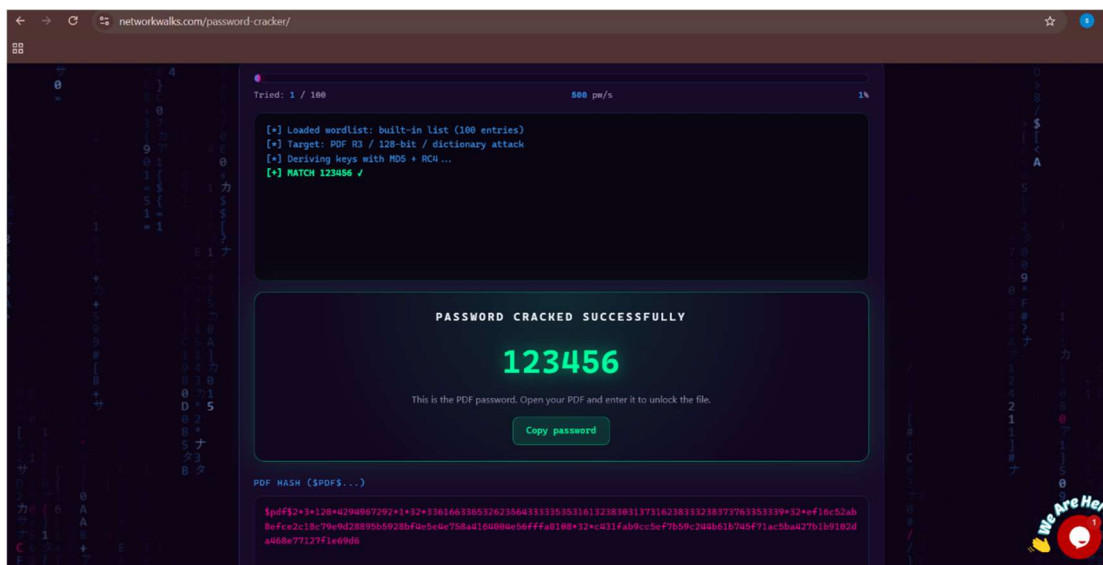


Figure 4: dictionary attack, run via the Networkwalks online password-cracker tool, matching the password "123456" against the report1 PDF hash.

Additional supporting captures of the second file were taken for the report record: a repeat view of the decrypted document, and a second cracking pass run through Networkwalks' hosted password-cracker utility (networkwalks.com/password-cracker/), which returned a match of "password" against the report2 PDF hash. Both weak, commonly-used passwords being visible underscores how trivially the document's encryption could be defeated.

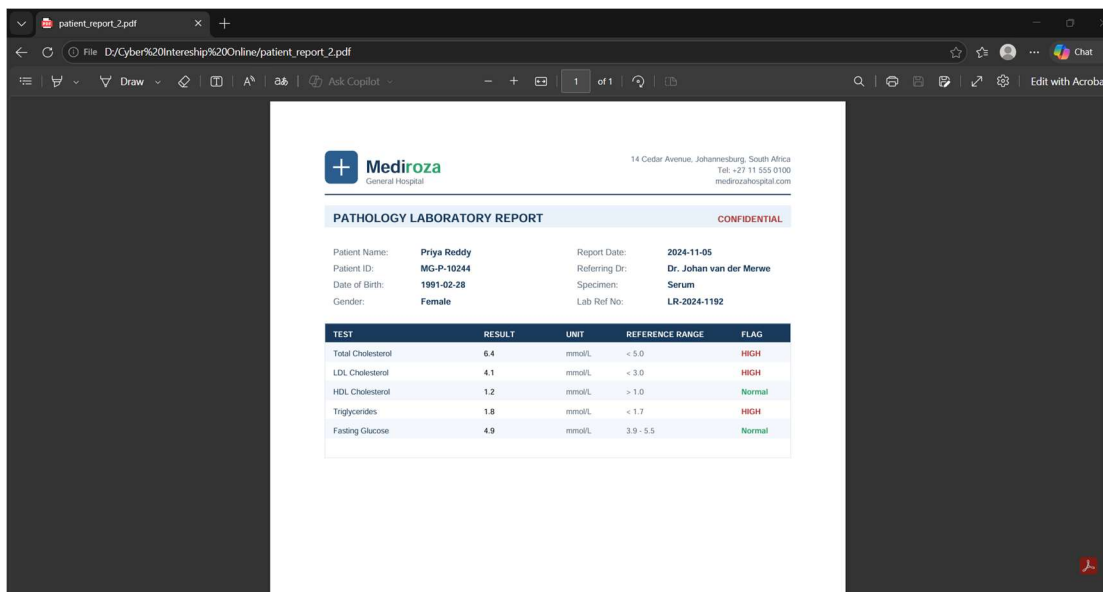


Figure 5. Retrieved and decrypted patient_report_2.pdf confirming its contents.

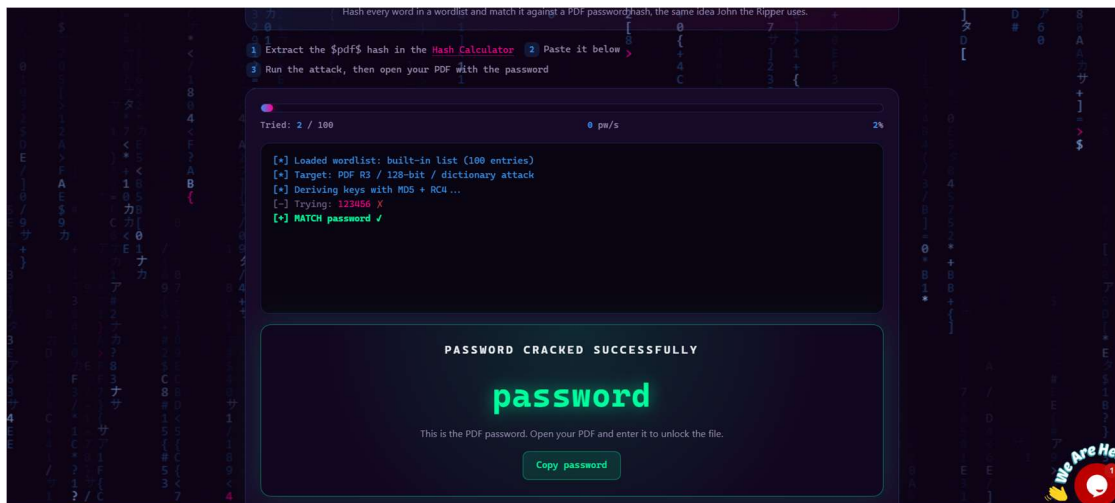


Figure 6. Dictionary attack against patient_report_2.pdf successfully recovering the password "password".

The third file used a stronger, non-dictionary password. A larger wordlist of 3,556 candidates including special-character patterns was required, and the password ("!@#\$%^&") was recovered near the end of the attack (candidate 3,546 of 3,556). This demonstrates inconsistent password strength practices across confidential documents generated by the hospital's systems.

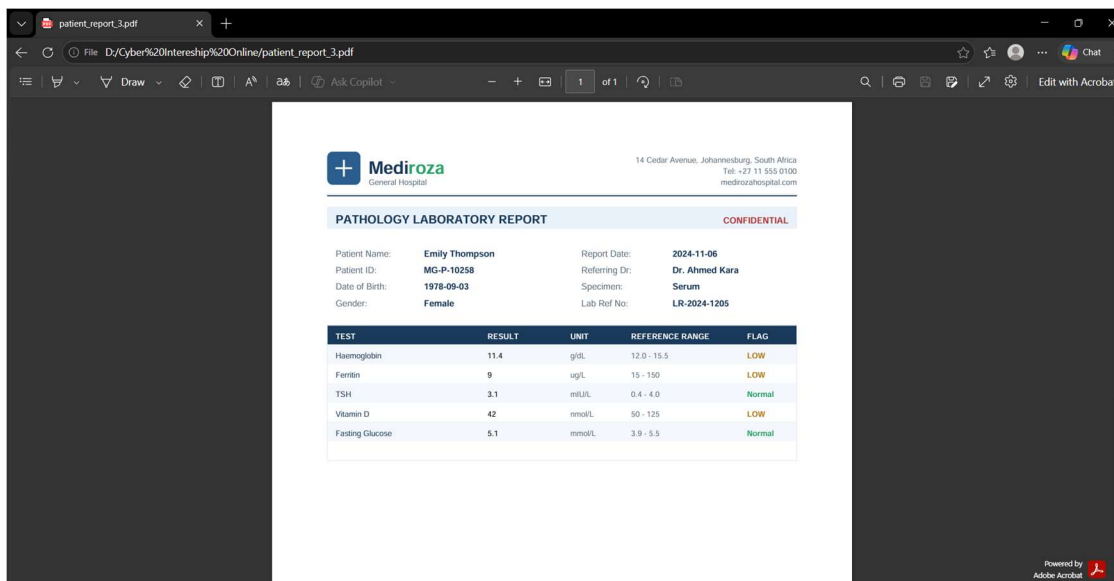


Figure 7. Retrieved and decrypted patient_report_3.pdf — pathology lab report for patient Emily Thompson.

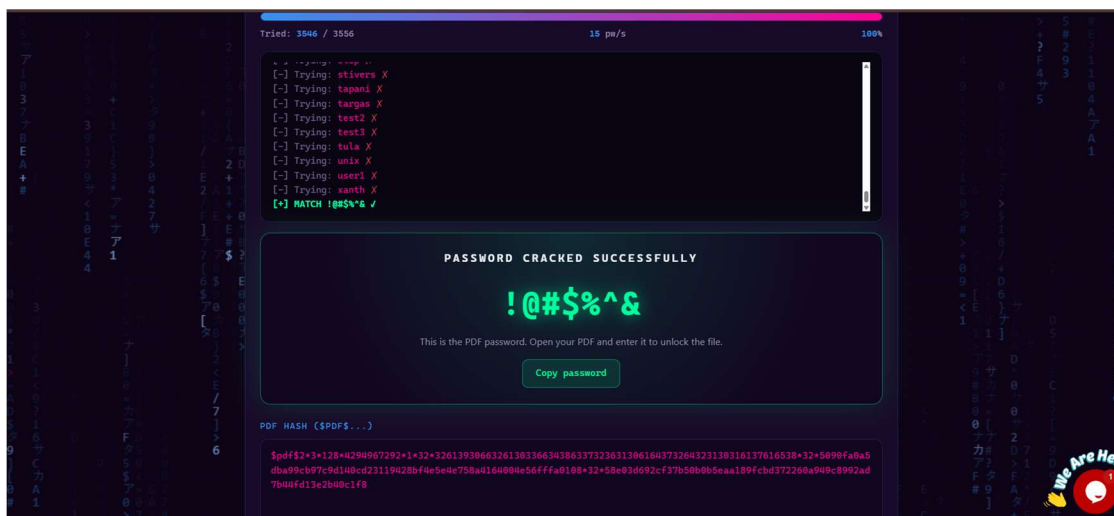


Figure 8. Extended dictionary/pattern attack against patient_report_3.pdf recovering the password "!@#\$%^&", with the underlying PDF encryption hash shown.

All three retrieved PDF reports were successfully decrypted, satisfying the Milestone 2 deliverable.

3.3 M3 — Exposed Internal Database Backup (Critical)

Following the assessment brief's guidance to examine file properties and go beyond the obvious content of items already retrieved, further analysis of the server led to the discovery of a legacy, unauthenticated database backup file: mediroza_db_backup_2019.sql. The file was generated by an outdated component (Mediroza CMS 1.4.2 backup module) on 2019-08-27 and was left accessible on the web server without any access control.

The backup contained a full export of the hospital's internal mediroza_hr database, including two tables of highly sensitive data:

- staff — 30 employee records including full name, job title, department, email, phone number, national ID number, monthly salary, and date joined.
- shareholders — 10 records detailing hospital ownership, including shareholder name, share percentage, number of shares held, and share class.

```
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table `staff`
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table `staff`
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','85021013011081',130000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099089',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123132083',33000,'2017-06-07'),
(13,'Bonangani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85031133143084',35000,'2015-12-01');
```

Figure 9. Header and staff table schema from the exposed mediroza_db_backup_2019.sql file.

```

LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','8502101311081',138000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099089',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123132083',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143084',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154085',42000,'2013-03-25'),
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165086',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Themba Mkosi','Radiographer','Radiology','t.mkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198089',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209081',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220082',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231083',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242084',118000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253085',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264086',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275087',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286088',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297089',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308081',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319082',38000,'2015-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330083',21000,'2019-11-05');
UNLOCK TABLES;

--
-- Table structure for table `shareholders`
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;

SET FOREIGN_KEY_CHECKS = 1;
-- End of backup

```

Figure 10. Staff record data and shareholders table schema from the exposed backup file.

```

(17,'Themba Mkosi','Radiographer','Radiology','t.mkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198089',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209081',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220082',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231083',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242084',118000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253085',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264086',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275087',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286088',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297089',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308081',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319082',38000,'2015-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330083',21000,'2019-11-05');
UNLOCK TABLES;

--
-- Table structure for table `shareholders`
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;

SET FOREIGN_KEY_CHECKS = 1;
-- End of backup

```

Figure 11. Shareholder records and end of the exposed backup file.

This single exposed file represents a severe breach of confidentiality, integrity of personal data, and corporate financial information. The full recovered contents are tabulated below for the client's reference.

Table 1 — Exposed Staff Records (staff table, 30 rows)

ID	Full Name	Job Title	Department	Email	Phone	National ID	Salary (ZAR)	Joined
1	Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	r.naidoo@medirozahospital.com	+27 82 101 2007	85021013011081	138,000	2009-03-16
2	Sarah Botha	Chief Financial Officer	Finance	s.botha@medirozahospital.com	+27 82 102 2014	85031023022082	152,000	2011-07-01
3	Dr. Johan van der Merwe	Medical Director	Management	j.merwe@medirozahospital.com	+27 82 103 2021	85041033033083	160,000	2007-01-22
4	Dr. Anita Naicker	Consultant Cardiologist	Cardiology	a.naicker@medirozahospital.com	+27 82 104 2028	85051043044084	132,000	2012-09-10
5	Dr. Ahmed Kara	Consultant Physician	Internal Medicine	a.kara@medirozahospital.com	+27 82 105 2035	85061053055085	128,000	2013-02-18
6	Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	y.cassim@medirozahospital.com	+27 82 106 2042	85071063066086	74,000	2018-05-04
7	Michael Roberts	HR Director	Human Resources	m.roberts@medirozahospital.com	+27 82 107 2049	85081073077087	96,000	2010-11-15
8	Susan Pretorius	HR Officer	Human Resources	s.pretorius@medirozahospital.com	+27 82 108 2056	85091083088088	32,000	2016-08-23
9	Jameel Malik	IT Systems Administrator	IT	j.malik@medirozahospital.com	+27 82 109 2063	85101093099080	58,000	2015-04-12
10	Thabo Molefe	Network Engineer	IT	t.molefe@medirozahospital.com	+27 82 110 2070	85111103110081	46,000	2017-10-02
11	Nomvula Khumalo	Registered Nurse	Emergency & Trauma	n.khumalo@medirozahospital.com	+27 82 111 2077	85121113121082	34,000	2016-01-19
12	Lerato Mokoena	Registered Nurse	Pediatrics	l.mokoena@medirozahospital.com	+27 82 112 2084	85011123132083	33,000	2017-06-07
13	Bongani Ndlovu	Registered Nurse	Cardiology	b.ndlovu@medirozahospital.com	+27 82 113 2091	85021133143084	35,000	2015-12-01
14	Zanele Mahlangu	Nursing Sister	Theatre	z.mahlangu@medirozahospital.com	+27 82 114 2098	85031143154085	42,000	2013-03-25
15	Kagiso Sithole	Pharmacist	Pharmacy	k.sithole@medirozahospital.com	+27 82 115 2105	85041153165086	61,000	2014-09-08
16	Naledi Zulu	Pharmacy Assistant	Pharmacy	n.zulu@medirozahospital.com	+27 82 116 2112	85051163176087	26,000	2019-02-14
17	Themba Nkosi	Radiographer	Radiology	t.nkosi@medirozahospital.com	+27 82 117 2119	85061173187088	44,000	2016-07-30
18	Palesa Radebe	Radiographer	Radiology	p.radebe@medirozahospital.com	+27 82 118 2126	85071183198080	43,000	2017-04-11
19	Deepak Pillay	Lab Technologist	Diagnostics Lab	d.pillay@medirozahospital.com	+27 82 119 2133	85081193209081	41,000	2015-05-20
20	Kavitha Govender	Lab Technician	Diagnostics Lab	k.govender@medirozahospital.com	+27 82 120 2140	85091203220082	35,000	2018-08-06
21	Dr. Suresh Moodley	Consultant Radiologist	Radiology	s.moodley@medirozahospital.com	+27 82 121 2147	85101213231083	130,000	2012-02-28
22	Dr. Fatima Patel	Pediatrician	Pediatrics	f.patel@medirozahospital.com	+27 82 122 2154	85111223242084	118,000	2013-10-17
23	Nisha Singh	Physiotherapist	Rehabilitation	n.singh@medirozahospital.com	+27 82 123 2161	85121233253085	48,000	2016-11-09
24	Dr. Vikram Chetty	Anaesthetist	Theatre	v.chetty@medirozahospital.com	+27 82 124 2168	85011243264086	135,000	2011-06-13
25	David Smith	Facilities Manager	Operations	d.smith@medirozahospital.com	+27 82 125 2175	85021253275087	52,000	2014-01-27
26	Karen O'Connor	Billing Administrator	Finance	k.oconnor@medirozahospital.com	+27 82 126 2182	85031263286088	29,000	2018-03-19
27	James Wilson	Security Supervisor	Operations	j.wilson@medirozahospital.com	+27 82 127 2189	85041273297080	27,000	2019-09-02
28	Linda Fourie	Receptionist	Front Office	l.fourie@medirozahospital.com	+27 82 128 2196	85051283308081	19,000	2020-02-10
29	Peter van Wyk	Procurement Officer	Supply Chain	p.wyk@medirozahospital.com	+27 82 129 2203	85061293319082	38,000	2015-08-24
30	Andile Mbeki	Ward Clerk	Administration	a.mbeki@medirozahospital.com	+27 82 130 2210	85071303330083	21,000	2019-11-05

Table 2 — Exposed Shareholder Records (shareholders table, 10 rows)

ID	Shareholder Name	Share %	Shares Held	Share Class
1	Dr. Rajesh Naidoo	18.0%	180,000	Ordinary
2	Cedar Health Holdings (Pty) Ltd	15.0%	150,000	Ordinary
3	Dr. Johan van der Merwe	12.0%	120,000	Ordinary
4	Reddy Family Trust	11.0%	110,000	Ordinary
5	Thabo Molefe	10.0%	100,000	Ordinary
6	Sarah Botha	9.0%	90,000	Ordinary
7	Dr. Ahmed Kara	8.0%	80,000	Preferential
8	Naledi Zulu	7.0%	70,000	Ordinary
9	Michael Roberts	6.0%	60,000	Ordinary
10	Dr. Vikram Chetty	4.0%	40,000	Preferential

Retrieval and documentation of this exposed data satisfies the Milestone 3 deliverable.

4. Risk Rating

Finding	Risk Rating	Justification
SQL Injection on Patient Portal login (patient/login.php)	Critical	Unauthenticated injection point allowed manipulation of backend SQL queries and bypass of authentication, leading to full compromise of patient records.
Weak / predictable encryption passwords on retrieved PDF lab reports	High	Confidential patient pathology reports were protected only by dictionary-crackable passwords (e.g. "password"), defeating the confidentiality control entirely.
Publicly exposed database backup file (mediroza_db_backup_2019.sql)	Critical	A legacy, unauthenticated backup file exposed 30 staff records (including national ID numbers and salaries) and 10 shareholder equity records.
Use of outdated CMS component (Mediroza CMS 1.4.2)	Medium	Outdated backup/CMS tooling generated the exposed backup and likely contains further known vulnerabilities.

5. Recommendations and Remediation

5.1 Authentication / SQL Injection

- Rewrite the login query using parameterised statements / prepared statements; never concatenate user input into SQL.
- Apply strict server-side input validation and output encoding on all form fields.
- Disable verbose database error messages in production; log errors server-side only.
- Deploy a Web Application Firewall (WAF) as a defence-in-depth measure

5.2 Document Encryption

- Enforce a minimum password complexity policy for all password-protected patient documents.

-
- Move from password-based PDF encryption to certificate-based encryption or a secure patient-portal delivery mechanism instead of emailing/serving password-protected files.

5.3 Exposed Backup File

- Immediately remove mediroza_db_backup_2019.sql (and any similar backup artefacts) from all publicly accessible web paths.
- Store backups outside the web root, encrypted at rest, with access restricted to authorised administrators only.
- Rotate/reset credentials and review exposure of national ID numbers for all 30 affected staff members; assess notification obligations under applicable data protection regulation (e.g. POPIA).
- Decommission or upgrade the outdated Mediroza CMS 1.4.2 backup module.
- Implement regular external attack-surface scanning to catch exposed files and directories going forward.

6. Conclusion

This engagement demonstrated that Mediroza General Hospital's patient portal is currently exposed to critical risk through a chained set of weaknesses: an SQL injection flaw enabling unauthorised access, weak document encryption undermining confidentiality of patient data once accessed, and a publicly exposed legacy database backup disclosing sensitive staff and shareholder information. Remediating the SQL injection vulnerability and removing the exposed backup file should be treated as immediate priorities, followed by the encryption and process improvements outlined above.

Author

Vijay Solanki
Cybersecurity Intern B082

LinkedIn: <https://www.linkedin.com/in/solanki-vijay/>

Project Information

Program Name: Cybersecurity program at Networkwalks | **Week:** 04 | **Repository:** GitHub